

## Task 2.1P

### External Entity: Software Developer

| Threat      | Description                                                                                                                                                                                                                                                                                                                                                                                                                   | Mitigation Techniques                                                                                                                                                                                                                 |
|-------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Spoofing    | This is when an attacker steals credentials (either via phishing or credential stuffing against the cloud based AD) and logs in as that developer. Using those credentials, the attacker could push malicious code disguised as proper legitimate source code. This will cause the loss of integrity of the code base as unauthorized code has now been pushed.                                                               | Enforce MFA on the AD login. Enforce proper password policies. Lock the account after a set number of repeated login attempts. Invalidate session tokens when the user logs out. Monitor login locations/devices for unusual entries. |
| Repudiation | This is when a developer deliberately/intentionally pushes vulnerable code to the code base and then denies having done that or claims their account was compromised. Because the system doesn't properly log any user actions, the auditors won't have any reliable way to prove who actually updated the code. This makes it difficult to find and hold the malicious user accountable, and it just overcomplicates things. | Implement proper logging on all the events. Ensure the logs are append only and read only. Use digital signatures to verify commits instead of just showing whatever the email address is.                                            |

### Process: Code Scanner (Application Server)

| Threat                  | Description                                                                                                                                                                                                                                                                                                                                                                                                                                                          | Mitigation Techniques                                                                                                                                                                                             |
|-------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Elevation of Privileges | This could be when an attacker uploads a malicious source file that exploits a vulnerability in the code scanner / static code analysis parser. Since it scans untrusted code, the attacker might be able to get their code running with the same permissions as the primary code scanning process. From there, they could attempt to recon and exploit more vulnerabilities to fully escalate privileges to the root user and potentially perform lateral movement. | Run the code scanner in sandbox following the principle of least privilege. Keep the code scanning engine up to date. Apply strict permissions (like disabling outbound network access for the code being tested) |
| Denial of Service       | This is when a malicious user either uploads a broken source file or an extremely large source file in order to overload the static code analyzers resource user to attempt to saturate the entire systems' resources. As a result of this, legitimate developers and managers might not be able to use the scanning service.                                                                                                                                        | Enforce upload size limits, file type validation, rate limiting, throttling, and run the services with their resource usages capped. If you have the budget, make it auto scalable.                               |

## Data Flow: Code Upload (Client —> Web Server, over the Internet)

| Threat                 | Description                                                                                                                                                                                                                                                                                                          | Mitigation Techniques                                                                                                                                                                                             |
|------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Tampering              | This is when an attacker intercepts the traffic between the developers browser/IDE and the web server and change the source files before it reaches the server. This means that the code that the server will deal with is not what the original developer uploaded. This violates non repudiation and integrity.    | Enforce HTTPS for all the data in transit with a valid and pinned certificate. Use HSTS to fight against downgrade attacks. Use integrity checks for uploaded files with content based file hashes.               |
| Information Disclosure | This is when connection between the developers browser/IDE to the server isn't properly encrypted. An attacker on the same network is easily able to listen in / eavesdrop / sniff the traffic sent over the network. This could result in confidential intellectual property being eavesdropped by malicious users. | Enforce encryption fore all API and web traffic. Use strong cipher suites. Use proper API authentication approaches with OAuth 2.0, tokens (like JWT), etc... Ensure not to log any sensitive data in plain text. |

## Data Store: Database Server (Scan Results and Vulnerability Data)

| Threat                 | Description                                                                                                                                                                                                                                                                                                                                                                                                              | Mitigation Techniques                                                                                                                                                                                                                                                                                                                                                                                    |
|------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Tampering              | This is when an attacker finds an injection vulnerability, like SQLi int he API or the application server and uses it to perform actions or access data that they are not authorized to. For example, they could delete detected vulnerabilities and let them through – thus making the security reports very unreliable, and gives the stakeholders a fake sense of security, leaving real vulnerabilities unaddressed. | Use an ORM, parameterized queries and prepared statements. Perform strict input validation and don't trust any user data. For the database accounts, follow the privilege of least principle. Enable logging of database actions for easier auditing.                                                                                                                                                    |
| Information Disclosure | This is when an attacker gains access to the database server by exploiting a vulnerability in the deployment/application. They will now have access to everything that this database account can do. If privilege is elevated in the database server accounts, the attacker will now be able to access and basically do anything to the data stored in this database server.                                             | Encrypt the data at rest. Restrict access to the database from external connections. Only allow access from the applications that are supposed to connect to it. Implement a role based access control system (RBAC) for the database user accounts / database service accounts and follow the principle of least privilege. Perform regular access reviews and monitor the database activity regularly. |